

Unit 18

Capstone CTF, Presentations & Careers / Certifications

Module 5 — Putting It Together · Week 18

The finale. Put it **all** together — and decide what's next.

Where we are — the finale

- All semester you learned each phase of the attack lifecycle **in isolation**.
- This week you **put it all together** on one authorized target.
- Working in teams: **recon → scan → exploit → privesc → document**.
- Then a **full report**, a **short presentation**, and a look at **careers**.

The ethics thread becomes a *life* commitment: staying legal and ethical for good.

What you'll be able to do

By the end of this unit you can:

- **Apply** the full attack lifecycle to an authorized capstone target.
- **Document** your work in a journal and a complete pentest report.
- **Present** findings clearly, framing authorization and impact.
- **Describe** major career paths using **CyberSeek** and the **NICE Framework**.
- **Sequence** a cert roadmap: **Security+** → **eJPT/PNPT** → **OSCP**.

What you'll be able to do (cont.)

- **Identify** competitions (picoCTF, NCL, CyberPatriot) and ways to build a **portfolio** and **home lab**.
- **Compare** college vs. self-study pathways and pick next steps.
- **Commit** to staying legal and ethical beyond the classroom — and explain why authorization protects your future.

Vocabulary — the capstone

Term	Meaning
Capstone	The final project: apply everything to one authorized target, report, present.
Attack lifecycle	recon → scan/enumerate → exploit → privilege-escalate → document.
CTF (Capture The Flag)	A legal, gamified challenge where you find hidden "flags."
Flag	A token (e.g., <code>picoCTF{...}</code>) proving you solved a challenge.
Rules of engagement (RoE)	The agreed rules and boundaries — what you may and may not do.

Vocabulary — career paths

Term	Meaning
SOC analyst	A defender who monitors alerts and responds to threats.
Red team	Offensive — simulates attackers to test defenses.
Blue team	Defensive — detects, responds, hardens systems.
Purple team	Red and blue working together to improve defenses.
GRC	Governance, Risk, and Compliance — the policy/risk/rules side.
AppSec	Application security — finding and fixing flaws in code.

Vocabulary — growth & credentials

Term	Meaning
CyberSeek	Free tool mapping cybersecurity jobs, demand, and pathways.
NICE Framework	National catalog of cybersecurity work roles, tasks, and skills.
Certification	A credential proving you passed an exam (Security+, OSCP...).
Security+	Widely-recognized entry-level cert — a common first step.
eJPT / PNPT	Beginner-to-intermediate practical pentesting certs.
OSCP	Hands-on offensive cert — the pro version of this course's content.
Home lab / Portfolio	Your own legal practice setup + a collection of your work.

Why this week matters

- All semester you practiced phases **one at a time**.
- A real test isn't separate skills — it's **one flowing process**.
- The capstone is where it all **clicks together**.
- And it's a real artifact: your **first complete project**.

This is the week the course turns into something you can show.

What you're graded on

- **Not** the number of flags you capture.
- The **report** and the **presentation** — your communication.
- **Honest documentation**, including dead ends.

A team with fewer flags but a clear, honest report can earn top marks.

Ethics & Authorization

The Day-1 rule is now a **life** rule, not a class rule.

The line that protects your career

- The single most important idea of the whole course:
- **Authorization and scope are the only line between a penetration tester and a criminal.**
- Every capstone target is picoCTF or an approved room: **legal, isolated, built to be attacked.**
- The same skills, on a real system without **written permission**, are a crime — and would **end** the very career you're aiming for.

Pros stay employable precisely because they stay in scope and get permission in writing.

Scope creep is the danger this week

- Under deadline stress, the temptation to "just try one more thing" is real.
- The **approved list is the entire universe of legal targets** this week.
- Not 100% sure a target is approved? **Stop and ask.**

Scope discipline is exactly what makes a professional employable.

Day 1

Capstone Kickoff & Plan; Recon Begins

Warm-up

Name the **five phases** of the attack lifecycle, in order.

The deliverables

This week your team produces:

1. A **team lab journal** with labeled evidence for every phase.
2. A complete **penetration-test report** (report rubric).
3. A **3-5 minute presentation** (presentation rubric).

The report and presentation are the graded deliverables — **not** the flag count.

Plan your team

- **Assign roles:** lead per phase, evidence/screenshots, report sections — but **everyone documents**.
- Decide **where notes live** (shared journal).
- Capture **labeled screenshots from minute one**.
- Write your **scope statement / RoE** before touching anything:

"We are authorized to test only [the approved target]. No other systems are in scope."

Exit ticket: Submit team scope statement + the first three things recon revealed.

Phase 1 — Recon (Day 1)

- Open the room/challenge brief; note in-scope hosts/URLs; identify the goal.
- Log everything — scope, target details, initial observations.

Capture: the RoE, target details, and your first observations.

Capture evidence from minute one

- Take a **labeled screenshot** of every key result.
- Copy the **exact command** that produced it.
- Thin notes today = a weak report on Day 4.

You can only report what you wrote down — start now.

Check your understanding

Your teammate gets a great result but only says *"trust me, it worked."*

Why won't that survive into the report?

Answer

- With no screenshot or command, it **can't be reproduced**.
- For the client, a finding with no proof **doesn't exist**.
- Re-run it, capture the command and a labeled screenshot.

No evidence, no finding. Document as you go.

Day 2

Scan / Enumerate → Exploit

Warm-up

What's the difference between **scanning** and **enumeration**? Give one tool for each.

Scanning vs. enumeration

- **Scanning** = *what's there?* — ports, hosts, services (nmap).
- **Enumeration** = *tell me more* — dig into one service for detail.
- Scanning finds the door; enumeration reads what's on it.

Scan wide, then enumerate deep on what looks promising.

Phase 2 — Scan / Enumerate

- Discover services, ports, versions, pages, users as appropriate.
- Tools you've used: `nmap`, `gobuster`, manual enumeration.

Figure 1: nmap shows port 80 running Apache 2.4.x

- **Capture** the exact commands and labeled screenshots of key results.

You can only report what you **wrote down**.

Phase 3 — Exploit

- Use what enumeration revealed to gain a **foothold**:
 - a vulnerable web input, weak/default credentials, a known public exploit used responsibly.
- Capture the **flag(s)** the challenge defines.

Capture: the vulnerability, exact steps/payload,
a labeled screenshot of success, the flag value.

Exit ticket: Submit one labeled screenshot + the command that produced it.

Day 3

Privilege Escalation → Finish Documenting

Warm-up

Name one **Linux privilege-escalation check** you'd run first, and why.

Phase 4 — Privilege escalation

- If applicable, escalate to higher privileges (a privesc check, a misconfiguration).
- **Not every target has a privesc.** If there isn't one — **document that honestly.**

Capture: the privesc path

OR "no privesc available — here's what we checked," with evidence.

Honest dead ends demonstrate the real skill. Reward accuracy over bravado.

Phase 5 — Document

- Transfer your journal into the **full report** (Unit 17 template):
 - executive summary, methodology, findings (evidence + justified severity + impact), remediation, appendices.
- **Restate scope/authorization.**

Exit ticket: One-line status — which phases are done, what evidence you have, what's left.

Honest dead ends are real skill

- Not every box has a privesc — and that's **fine**.
- "We tried X, Y, Z and found no path" is a **valid finding**.
- Inventing a result to look better fails the ethics test.

A documented dead end beats a made-up win every time.

Severity inflation comes back under pressure

- Deadline stress brings the "everything is Critical" reflex.
- Keep enforcing **likelihood × impact**:

Critical	Low
Unauth RCE; dumping customer data	Verbose error leaking a version number

A true Critical is rare. Justify every rating.

Check your understanding

Your team captured only one flag, but documented every step honestly with evidence.

Will you score well? Why?

Answer

- **Yes** — the grade is the **report and presentation**, not flags.
- Clear, honest, well-evidenced work meets the goal.
- Accuracy over bravado — every time.

Fewer flags, fully documented, can still earn top marks.

Day 4

Write the Full Report + Careers & Certifications

Warm-up

Which **report rubric row** will your team focus on today?

Career paths in this field

Path	What they do
Pentester / Red team	Simulate attackers on authorized tests
SOC analyst / Blue team	Monitor, detect, respond
Purple team	Red + blue improving defenses together
GRC	Policy, risk, compliance
AppSec	Find & fix flaws in software
IR / Threat intel	Respond to incidents; track adversaries

Use **CyberSeek** and the **NICE Framework** to explore real demand and roles.

Red team — the offense

- **Simulates real attackers** on authorized tests.
- This is the work this whole course previewed.
- Day-to-day: recon, exploit, privesc, **and reporting**.

The job you tasted in the capstone — done for a living.

Blue team & the SOC

- **Defenders** who watch, detect, and respond to threats.
- A **SOC analyst** monitors alerts in real time.
- Often the **most common entry door** into the field.

Every attack you learned, a blue-teamer is trained to catch.

Purple, GRC & AppSec

- **Purple team:** red and blue working **together** to improve.
- **GRC:** the policy, risk, and rules side — heavy on writing.
- **AppSec:** find and fix security flaws **in the code itself**.

Not every path is "hacking." The field is wide.

You don't have to attack to belong

- Detection, response, policy, and code review are all security.
- Strong **writing** (your Unit 17 skill) helps in **every** role.
- Pick the part of the work that you actually enjoy.

There's a seat here whether you love breaking or building.

Check your understanding

Which role mostly **monitors alerts and responds** to threats, rather than attacking?

Answer

- The **SOC analyst** (blue team) monitors and responds.
- Red team attacks; blue team defends; purple bridges them.
- All three need the attack knowledge you built here.

Knowing the attack makes you a better defender, too.

CyberSeek & NICE

- **CyberSeek** maps real **jobs, demand, and salaries** — free.
- **NICE Framework** names the **work roles, tasks, and skills**.
- Use both to turn "I like security" into a concrete plan.

Real data beats guessing. Explore where the jobs actually are.

The certification roadmap

Security+ → eJPT / PNPT → OSCP → and beyond
(entry, (beginner-to- (hands-on
broad) intermediate professional
practical) offensive)

- **Security+** — broad, recognized first step.
- **eJPT / PNPT** — practical pentesting fundamentals.
- **OSCP** — the hands-on pro version of this course's skills.

Certs build on each other. You don't get them all at once.

Security+ — the first step

- Broad, **entry-level**, widely recognized by employers.
- Multiple-choice; covers attacks, defense, and operations.
- A common requirement for a **first security job**.

If you study one cert next, this is usually it.

eJPT / PNPT — going hands-on

- **Practical** exams: you actually hack a lab, not just answer questions.
- A natural step **after** Security+ for offensive interest.
- PNPT even requires you to **write a report** — like Unit 17.

The bridge between "knows the words" and "can do the work."

OSCP — the pro milestone

- A hard, hands-on exam: compromise machines in a **timed lab**.
- Then write a full **report** — pass requires both.
- The professional version of **everything in this course**.

A real goal — earned over years, not weeks. You've started.

Check your understanding

A friend wants to "get OSCP first because it's the most respected."

What would you advise, and why?

Answer

- Start with **Security+**, then a practical cert like **eJPT/PNPT**.
- OSCP assumes skills the earlier steps build first.
- Certs **stack** — skipping to the top usually backfires.

Climb the ladder. Each rung makes the next one reachable.

Competitions & building a portfolio

- **Competitions:** picoCTF, National Cyber League (NCL), CyberPatriot.
- **Home lab:** a safe, isolated environment you build to keep practicing **legally**.
- **Portfolio:** sanitized writeups, lab journals, projects that show what you can do.

Many great practitioners are self-taught; many went to college. **Consistency beats either.**

Build a home lab

- A **safe, isolated** setup you build to keep practicing legally.
- Free VMs, intentionally-vulnerable boxes, picoCTF.
- Your own lab = unlimited practice with **zero legal risk**.

The lab is where you stay sharp without crossing the line.

Build a portfolio

- A collection of **sanitized writeups**, lab journals, and projects.
- Shows an employer what you can **actually do** — not just claim.
- Your capstone report could be your **first portfolio piece**.

A portfolio turns "I'm interested" into "here's my proof."

College vs. self-study

- **Both work.** Neither is the only path.
- College: structure, a network, a degree.
- Self-study: flexible, cheaper, portfolio-driven.
- What matters most: **consistency, projects, and a portfolio.**

Pick the next step that fits *you* — and keep going.

Check your understanding

Name **one legal** way to keep building these skills after this class.

Answer (any one)

- **picoCTF** or another authorized CTF.
- **NCL** or **CyberPatriot** competitions.
- Your own **home lab** of intentionally-vulnerable VMs.

Plenty of legal practice. Zero excuses to go off-scope.

Write the report (Day 4)

- Teams **write the full report** (all five sections, evidence, justified severities, remediation).
- Build a **3-5 slide** presentation deck.
- Individuals begin the **careers research mini-task**.

Exit ticket: Name one career path and one certification that interest you, and your honest next step after this class.

Day 5

Presentations + Course Reflection

Warm-up

Read the **presentation rubric** aloud — note the **ethics-framing** row.

Criteria	What it checks
Content accuracy	Technically correct & complete
Clarity & delivery	Engaging, clear, well-paced
Ethics framing	Explicitly addresses authorization/impact

Your 3-5 minute talk

Five slides:

- 1. Target & scope / authorization**
- 2. Methodology / lifecycle**
- 3. Top findings + severity**
- 4. Remediation**
- 5. What we learned + ethics**

The ethics-framing row is required: state your authorization and the real-world impact.

Careers research mini-task

Pick one role on **CyberSeek** and write a ½–1 page brief:

1. The **role** and its day-to-day.
2. **Typical skills** + one **NICE work role** it maps to.
3. **Demand & pay** info from CyberSeek.
4. **One certification** and where it fits the roadmap.
5. Your **honest next step** after this class.

Final course reflection

In ½–1 page:

- One skill you're **proud** of learning, and one thing that was **hard**.
- Restate, in your own words, the course's **central ethics rule** and how you'll apply it for life.
- What you'll do next to keep learning **legally**.

Submit the full report and the reflection. Then — celebrate.

Unit recap

- You ran the **full lifecycle** on an authorized target, end to end.
- Documentation and honesty — **not flag count** — drive the grade.
- Careers: red/blue/purple, SOC, GRC, AppSec, IR, threat intel.
- Roadmap: **Security+ → eJPT/PNPT → OSCP**.
- Keep practicing **legally**: picoCTF, NCL, home lab, portfolio.

Exit Discussion

It's five years from now. You have real skills.

A friend asks: *"Just check if my ex's account can be hacked — it'll take you five minutes."*

Walk through exactly what you say and why. What would saying **yes** cost you — legally, professionally, ethically? How is this the same lesson as **Day 1**?

The line you'll carry for life

On **Day 1** we said: *authorization and scope are the only line between a penetration tester and a criminal.*

That hasn't changed — it's the rule that will **protect your career** for the rest of your life.

Get permission in writing. Stay in scope. Disclose responsibly.

You have real, powerful skills now. Use them to **defend** — and go build something.